Unicorn System Dashboard - Analys & Förbättringsförslag

System Dashboard för Unicorn - Professionell Analys & Förbättringsförslag
Sammanfattning
1. Styrkor i Nuvarande Specifikation
   ✅ Utmärkta Aspekter
2. Identifierade Gap & Förbättringsområden
   🔴 Kritiska Gap
   🟠 Viktiga Gap
   🟢 Nice-to-Have Gap
3. Prioriterade Förbättringsförslag
   🔥 Must-Have (Kritiska)
   ⭐ Should-Have (Viktiga)
   💡 Nice-to-Have (Framtida)
4. Förbättrad Feature-Lista
   Brand Customization (Enhanced)
   Industrimall (16 totalt)
   Användarhantering (Enhanced)
   Säkerhet & Compliance
   Analytics & Reporting
   Internationalisering
   Integrationer
   White-Labeling Pro
5. Databas Schema Förslag
   Core Tables
   Branding Tables
   Audit & Logging Tables
   Analytics Tables
   File Storage Tables
   Integration Tables
6. API Endpoint Specifikationer
   Base URL
   Authentication
   Response Format
   Tenant Management
   User Management
   Branding Management
   Branding Templates
   File Management
   Analytics

Audit Logs
Webhooks
API Rate Limits
7. Säkerhetsbästa Praxis
7.1 Authentication & Authorization
7.2 Data Security
7.3 API Security
7.4 File Upload Security
7.5 Compliance
7.6 Monitoring & Incident Response
8. UX/UI Rekommendationer
8.1 Navigation & Information Architecture
8.2 Branding Interface
8.3 User Management Interface
8.4 Role Management
8.5 Dashboard & Analytics
8.6 Accessibility (WCAG 2.1 AA)
8.7 Feedback & Validation
9. Skalbarhet & Performance
9.1 Database Optimization
9.2 Caching Strategy
9.3 Asynchronous Processing
9.4 Horizontal Scaling
9.5 Performance Monitoring
10. Implementeringsplan (Roadmap)
Fas 1: MVP (8-10 veckor)
Fas 2: Enhanced Security & UX (4-6 veckor)
Fas 3: Analytics & Reporting (3-4 veckor)
Fas 4: Internationalization & Advanced Features (4-6 veckor)
Fas 5: Integrations & Enterprise Features (6-8 veckor)
Fas 6: Scale & Optimize (4-6 veckor)
Ongoing: Maintenance & Iteration
11. Prioriterad Feature-Lista för Utveckling
Must-Have (MVP - Fas 1)
Should-Have (Fas 2-3)
Nice-to-Have (Fas 4-6)
Future Consideration
12. Teknisk Arkitektur Rekommendation
Tech Stack Förslag
Folder Structure (NestJS exempel)
13. Sammanfattning & Nästa Steg
Översikt
Styrkor
Kritiska Förbättringsområden
Rekommenderad Approach
ROI-Fokus
Success Metrics
Nästa Steg

Bilaga A: Nordiska Marknaden Considerations
Språk & Lokalisering
Affärskultur
Juridiska Krav
Betalning & Valuta
Konkurrensanalys (Exempel)
Bilaga B: Ordlista (Svenska Tech Terms)

System Dashboard för Unicorn - Professionell Analys & Förbättringsförslag

Sammanfattning

System Dashboard-specifikationen för Unicorn utgör en solid grund för multi-tenant white-labeling och användarhantering. Planen visar god förståelse för kärnfunktionalitet men kan förbättras inom områdena säkerhet, skalbarhet, användarupplevelse och affärsvärde. Detta dokument presenterar en djupgående analys med konkreta förbättringsförslag och implementeringsplan.

---

1. Styrkor i Nuvarande Specifikation

✅ Utmärkta Aspekter

Multi-Tenant Arkitektur - Tydlig tenant-isolering genom användarhantering per kund - Rollbaserad åtkomstkontroll (RBAC) är väldefinierad - God separation mellan systemägare och slutkunder

White-Labeling Funktionalitet - Omfattande anpassningsmöjligheter (färger, logotyp, texter) - Live preview-funktionalitet är utmärkt för användarupplevelse - Industrimall-konceptet är innovativt och tidsbesparande

Användarvänlighet - Fördefinierade mallar minskar inställningstid - Live preview reducerar fel och omarbete - Tydlig rollstruktur underlättar administration

Teknisk Genomtänkthet - CSS-variabler för dynamisk teaming är modern och effektiv - API-först approach möjliggör framtida integrationer - Säkerhetsmedvetenhet för filuppladdning och åtkomstkontroll

---

2. Identifierade Gap & Förbättringsområden

🔴 Kritiska Gap

2.1 Säkerhet & Compliance

Problem: - Ingen mention av audit logging för ändringar - Saknar session management och concurrent access control - Inga detaljer om GDPR-compliance för användardata - Begränsad information om API-autentisering och rate limiting

Risk: Potentiella säkerhetsbrister och compliance-problem

2.2 Dataisolering & Tenant-Säkerhet

Problem: - Ingen explicit mention av data isolation strategies - Saknar skydd mot tenant cross-contamination - Inga detaljer om hur tenant context hanteras i API-anrop

Risk: Allvarlig säkerhetsrisk om data läcker mellan tenants

2.3 Backup & Återställning

Problem: - Ingen strategi för att återställa tidigare branding - Saknar versionering av branding-ändringar - Inga rollback-mekanismer

Risk: Permanent förlust av konfiguration vid misstag

🟠 Viktiga Gap

2.4 Användarupplevelse

Problem: - Ingen bulk user import/export funktionalitet - Saknar användarnotifieringar vid kontoskapande - Ingen självbetjäning för användarprofiler - Begränsad feedback för API-operationer

Impact: Reducerad effektivitet för admins

2.5 Rapportering & Insikter

Problem: - Ingen dashboard analytics eller usage metrics - Saknar user activity tracking - Ingen rapportering om systemanvändning per tenant

Impact: Svårt att optimera och förstå användarmönster

2.6 Internationalisering

Problem: - Ingen språkstöd (kritiskt för Norden: Svenska, Norska, Danska, Finska) - Saknar timezone-hantering för olika marknader - Inga lokaliserade datumformat

Impact: Begränsad marknadspotential i Norden

2.7 Branding-Flexibilitet

Problem: - Endast 3 färger - moderna designsystem behöver fler nyanser - Ingen typografianpassning - Saknar custom CSS capabilities för avancerade användare - Ingen favicon-hantering

Impact: Begränsad brand differentiation

🟢 Nice-to-Have Gap

2.8 Integration & Automation

- Ingen webhook-support för systemhändelser
- Saknar SSO/SAML integration
- Ingen API dokumentation generation
- Begränsad automation av användarprovisionering

2.9 Template Management

- Endast 8 fördefinierade mallar
- Ingen möjlighet att skapa custom templates
- Saknar template marketplace eller sharing

---

3. Prioriterade Förbättringsförslag

🔥 Must-Have (Kritiska)

3.1 Förbättrad Säkerhet

Audit Logging System

```
Funktionalitet:
- Logga alla ändringar i branding (vem, vad, när)
- Spåra användarhantering (skapande, redigering, borttagning)
- Logga inloggningsförsök och åtkomstkontroll
- Exportera audit logs för compliance

Värde:
- GDPR-compliance
- Forensic analysis vid säkerhetsincidenter
- Transparens för kunder
```

Data Isolation Layer

```
Implementering:
- Row-Level Security (RLS) i databas
- Tenant context middleware för alla API-anrop
- Automatisk tenant_id injection i queries
- Validering av tenant access vid varje operation

Schema exempel:
CREATE POLICY tenant_isolation ON users
  USING (tenant_id = current_setting('app.current_tenant')::uuid);
```

API Security

```
Features:
- JWT-baserad autentisering med tenant claims
- Rate limiting per tenant (förhindra DOS)
- API key rotation
- CORS policies per tenant
- Request signing för känsliga operationer
```

3.2 Backup & Versionering

Branding Version Control

```
Features:
- Automatisk versionering vid varje ändring
- "Publish" vs "Draft" lägen
- Återställ till tidigare version
- A/B testing av branding
- Scheduled branding changes (t.ex. säsongsanpassning)

Database schema:
Table: branding_versions
- id, tenant_id, version, config_json, published
- created_by, created_at, published_at
```

3.3 Internationalisering (i18n)

Multi-Language Support

```
Språk:
- Svenska (primär)
- Norska (Bokmål & Nynorsk)
- Danska
- Finska
- Engelska

Implementering:
- i18n library (react-i18next, vue-i18n)
```

```
- Språkval per användare OCH per tenant
- Översättningsgränssnitt i System Dashboard
- Automatiska översättningar för mallar
```

Regional Settings

```
Features:
- Timezone per tenant
- Datum/tid format preferences
- Valuta och nummerformat
- Lokala helgdagar (för schemaläggning)
```

3.4 Förbättrad Användarhantering

Bulk Operations

```
Features:
- CSV import av användare
- Bulk role assignment
- Mass email till användare
- Grupphantering (teams inom tenant)

CSV format exempel:
email,first_name,last_name,role,phone,team
user@company.com,John,Doe,user,+46701234567,Installation
```

User Self-Service Portal

```
Features:
- Användare kan uppdatera egen profil
- Lösenordsåterställning
- Notifikationsinställningar
- 2FA activation
```

Enhanced Notifications

```
Triggers:
- Welcome email vid kontoskapande (med inloggningsinstruktioner)
- Lösenordsåterställning
- Rolländringar
- Licens-varningar (approaching limits)
- System maintenance notifications

Kanaler:
- Email (primär)
- SMS (för kritiska notifikationer)
- In-app notifications
```

☆ Should-Have (Viktiga)

3.5 Analytics & Reporting Dashboard

System Owner Dashboard

```
Metrics:
- Active tenants och användare
- Licensutnyttjande per tenant
- API usage och performance metrics
- Feature adoption rates
- Revenue metrics (MRR, churn)

Visualiseringar:
- Trendgrafer över tid
- Tenant health scores
- Usage heatmaps
- Geographic distribution
```

Tenant Admin Dashboard

```
Metrics:
- User activity logs
- Feature usage inom tenant
- Field service metrics integration
- Team performance (om relevant)
```

3.6 Utökad Branding

Extended Color Palette

```
Istället för 3 färger:
- Primary: main, light, dark (3 nyanser)
- Secondary: main, light, dark (3 nyanser)
- Accent: success, warning, error, info (4 färger)
- Neutral: backgrounds, borders, text (5 grays)
- Totalt: 15 färger för komplett designsystem
```

Typography System

```
Features:
- Font family selection (Google Fonts integration)
- Font sizes och weights för headers, body, UI
- Line heights och letter spacing
- Custom font upload (advanced)
```

Advanced Branding

```
Features:
- Favicon upload
- Email template branding
- PDF report headers/footers
```

```
- Loading screen branding
- Custom CSS injection (för advanced users)
- Dark mode toggle och konfiguration
```

3.7 Template Management

Custom Templates

```
Features:
- Skapa egna templates från nuvarande config
- Spara och återanvänd templates
- Dela templates mellan tenants (opt-in)
- Template marketplace (framtida)
```

Fler Industrimall

```
Föreslagna tillägg:
9. Landscape & Garden Services
10. Security Services
11. Automotive Services
12. Home Healthcare
13. Moving Services
14. Pest Control
15. Telecommunications
16. Solar & Renewable Energy

Nordisk fokus: Anpassa mallar för nordiska marknaden med lokala
färgpreferenser
```

3.8 Förbättrad Role Management

Granular Permissions

```
Istället för 3 roller, implementera permission-based system:

Permissions:
- branding.view, branding.edit
- users.view, users.create, users.edit, users.delete
- billing.view, billing.edit
- reports.view, reports.export
- settings.view, settings.edit
- api.access

Roles som permission bundles:
- Owner: all permissions
- Admin: all except billing och kritiska settings
- Manager: users, reports, moderate branding
- User: minimal permissions
```

```
Benefit: Mycket större flexibilitet för olika
organisationsstrukturer
```

Custom Roles

```
Features:
- Tenant admins kan skapa egna roller
- Koppla permissions till custom roles
- Role templates för vanliga use cases
```

💡 Nice-to-Have (Framtida)

3.9 Integration Ecosystem

SSO Integration

```
Standards:
- SAML 2.0
- OAuth 2.0 / OpenID Connect
- Azure AD / Entra ID
- Google Workspace

Benefit: Enterprise-ready, reducerar lösenordshantering
```

Webhooks

```
Events:
- tenant.created, tenant.updated
- user.created, user.deleted, user.role_changed
- branding.updated
- license.approaching_limit

Use cases:
- Automatisk provisionering i externa system
- CRM synkronisering
- Custom alerting
```

API Marketplace

```
Features:
- Dokumenterad public API
- API keys med scoped permissions
- Developer portal med docs
- Rate limits per API tier
- Sandbox environment
```

3.10 White-Label Portal

Helt Branding Portal

```
Features:
- Custom domain per tenant (app.customer.com)
- SSL certificate management
- Branded login pages
- Branded email domains
- iOS/Android app white-labeling (framtida)
```

3.11 AI-Driven Features

Intelligent Branding Suggestions

```
Features:
- AI-genererade färgpaletter från logotyp
- Brand accessibility scoring (WCAG contrast)
- Kompletterande färgförslag
- Logo quality analysis
```

Predictive Analytics

```
Features:
- Churn prediction per tenant
- Usage anomaly detection
- Capacity planning recommendations
```

---

4. Förbättrad Feature-Lista

Brand Customization (Enhanced)

Färger (15 istället för 3) - Primary: main, light, dark - Secondary: main, light, dark
- Accent: success, warning, error, info - Neutral: 5 gray shades - Auto-generate accessible color variations

Typography - Font family selection (Google Fonts + custom upload) - Size system (h1-h6, body, caption, button) - Weight system (light, regular, medium, bold) - Line height och letter spacing presets

Logotyper - Main logo (horizontal) - Icon/favicon - Logo variant för dark backgrounds - Loading spinner logo - Email header logo

Preview System - Live preview på flera komponenter (dashboard, forms, reports) - Mobile preview - Dark mode preview - Accessibility checker (contrast ratios) - Export preview as images

Versionering - Save drafts - Publish/unpublish - Version history med rollback - Schedule publishing - A/B test variants

Industrimall (16 totalt)

Nuvarande 8 + 8 nya:

Nya mallar: 9. Landscape & Garden Services 10. Security Services 11. Automotive Services 12. Home Healthcare 13. Moving Services 14. Pest Control 15. Telecommunications 16. Solar & Renewable Energy

Mallfunktioner: - Preview alla mallar innan applicering - Anpassa mall innan sparande - Skapa egna templates - Importera/exportera templates - Template marketplace (community sharing)

Användarhantering (Enhanced)

List View - Advanced filtering (role, status, team, location) - Sortering på alla kolumner - Search by name, email, phone - Bulk selection - Export to CSV/Excel - Pagination med adjustable page size

User CRUD - Create: Single + bulk import from CSV - Read: Detailed user profile med activity history - Update: Edit all fields + role assignment - Delete: Soft delete med recovery option - Deactivate/Reactivate users

Roller och Permissions - Owner, Admin, Manager, User (standard) - Custom roles med granular permissions - Permission inheritance - Role templates - Temporary role elevation (time-limited)

Teams & Grupper - Skapa teams inom tenant (t.ex. Installation Team, Service Team) - Assign users till flera teams - Team-based permissions - Team leaders med elevated permissions

User Self-Service - Profile editing - Password change - 2FA enrollment - Notification preferences - Session management (view/revoke active sessions)

Notifikationer - Welcome email med credentials - Password reset - Role change notifications - Account deactivation warning - License limit warnings

Säkerhet & Compliance

Authentication - Email/password (med strong password policy) - 2FA (TOTP, SMS) - SSO (SAML, OAuth) - Session management (timeout, concurrent session control) - Password expiration policy

Authorization - Row-level security (RLS) för tenant isolation - Permission-based access control - API authentication (JWT, API keys) - Rate limiting per tenant/user

Audit & Compliance - Comprehensive audit logging - GDPR compliance tools (data export, deletion) - Retention policies - Compliance reports - Data encryption (at rest, in transit)

Backup & Recovery - Automated backups (daily) - Point-in-time recovery - Configuration versioning - Export tenant data - Disaster recovery procedures

Analytics & Reporting

System Owner Analytics - Tenant overview (total, active, churned) - Revenue metrics (MRR, ARR, churn rate) - User statistics (total users, per tenant avg) - API usage och performance - Feature adoption rates - Geographic distribution - License utilization

Tenant Admin Analytics - User activity (login frequency, feature usage) - Team performance metrics - API usage för tenant - Storage usage - Support ticket metrics (om integrerat)

Dashboards - Customizable widgets - Real-time updates - Export reports (PDF, Excel) - Scheduled reports via email - Custom date ranges

Internationalisering

Språkstöd - Svenska (primär för Norden) - Norska (Bokmål & Nynorsk) - Danska - Finska - Engelska - Språkväxlare i UI - User-level språkpreferens - Tenant-level default språk

Regional Settings - Timezone per tenant - Date/time format - Number format - Currency - Week start day - Lokala helgdagar

Översättningshantering - Translation interface för tenants - Custom text overrides - Translation memory - Machine translation suggestions (AI)

Integrationer

SSO Providers - Microsoft Azure AD / Entra ID - Google Workspace - Okta - OneLogin - Generic SAML 2.0 - OAuth 2.0 / OIDC

Webhooks - Configurable event subscriptions - Retry logic med exponential backoff - Webhook logs och debugging - Payload signing - Test webhook functionality

API - RESTful API med OpenAPI (Swagger) docs - GraphQL API (framtida) - API versioning - SDK generation (Python, JavaScript, C#) - Sandbox environment

White-Labeling Pro

Custom Domains - Tenant-specific subdomains (customer.unicorn.app) - Fully custom domains (app.customer.com) - Automatic SSL certificates - DNS management guidance

Branded Assets - Login page branding - Email template branding - PDF report branding - Mobile app icon/splash (framtida) - Browser tab title/favicon

Advanced Theming - Custom CSS injection - Component-level styling - Branded loading states - Custom error pages - Branded maintenance pages

---

5. Databas Schema Förslag

Core Tables

tenants

```sql
CREATE TABLE tenants (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    name VARCHAR(255) NOT NULL,
    slug VARCHAR(100) UNIQUE NOT NULL, -- för URL:
        app.unicorn.com/tenant-slug
    subdomain VARCHAR(63) UNIQUE, -- customer.unicorn.app
    custom_domain VARCHAR(255) UNIQUE, -- app.customer.com
    status VARCHAR(20) DEFAULT 'active', -- active, suspended,
        cancelled
    tier VARCHAR(50) DEFAULT 'basic', -- basic, professional,
        enterprise
    max_users INTEGER DEFAULT 10,
    features JSONB DEFAULT '{}', -- feature flags
    metadata JSONB DEFAULT '{}',
    created_at TIMESTAMP DEFAULT NOW(),
    updated_at TIMESTAMP DEFAULT NOW(),
    deleted_at TIMESTAMP -- soft delete
);

CREATE INDEX idx_tenants_slug ON tenants(slug);
CREATE INDEX idx_tenants_status ON tenants(status);
```

users

```sql
CREATE TABLE users (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE
        CASCADE,
    email VARCHAR(255) NOT NULL,
```

```sql
    email_verified BOOLEAN DEFAULT FALSE,
    password_hash VARCHAR(255), -- null om SSO
    first_name VARCHAR(100),
    last_name VARCHAR(100),
    phone VARCHAR(20),
    avatar_url VARCHAR(500),
    locale VARCHAR(10) DEFAULT 'sv-SE', -- språk
    timezone VARCHAR(50) DEFAULT 'Europe/Stockholm',
    status VARCHAR(20) DEFAULT 'active', -- active, inactive,
        suspended
    last_login_at TIMESTAMP,
    password_changed_at TIMESTAMP,
    two_factor_enabled BOOLEAN DEFAULT FALSE,
    two_factor_secret VARCHAR(255),
    metadata JSONB DEFAULT '{}',
    created_at TIMESTAMP DEFAULT NOW(),
    updated_at TIMESTAMP DEFAULT NOW(),
    deleted_at TIMESTAMP,
    UNIQUE(tenant_id, email)
);

CREATE INDEX idx_users_tenant ON users(tenant_id);
CREATE INDEX idx_users_email ON users(email);
CREATE INDEX idx_users_status ON users(status);

-- Row Level Security
ALTER TABLE users ENABLE ROW LEVEL SECURITY;

CREATE POLICY tenant_isolation ON users
    USING (tenant_id = current_setting('app.current_tenant')::uuid);
```

roles

```sql
CREATE TABLE roles (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID REFERENCES tenants(id) ON DELETE CASCADE, -- null
        för system roles
    name VARCHAR(50) NOT NULL,
    slug VARCHAR(50) NOT NULL,
    description TEXT,
    permissions JSONB DEFAULT '[]', -- array av permission strings
    is_system BOOLEAN DEFAULT FALSE, -- system roles kan ej raderas
    created_at TIMESTAMP DEFAULT NOW(),
    updated_at TIMESTAMP DEFAULT NOW(),
    UNIQUE(tenant_id, slug)
);

-- System roles (tenant_id = NULL)
INSERT INTO roles (name, slug, permissions, is_system) VALUES
```

```sql
('Owner', 'owner', '["*"]', TRUE),
('Admin', 'admin', '["users.*", "branding.*", "reports.view"]',
        TRUE),
('Manager', 'manager', '["users.view", "users.create",
        "branding.view", "reports.view"]', TRUE),
('User', 'user', '["profile.view", "profile.edit"]', TRUE);
```

user_roles

```sql
CREATE TABLE user_roles (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    role_id UUID NOT NULL REFERENCES roles(id) ON DELETE CASCADE,
    assigned_by UUID REFERENCES users(id),
    assigned_at TIMESTAMP DEFAULT NOW(),
    expires_at TIMESTAMP, -- för temporary role elevation
    UNIQUE(user_id, role_id)
);

CREATE INDEX idx_user_roles_user ON user_roles(user_id);
CREATE INDEX idx_user_roles_role ON user_roles(role_id);
```

teams

```sql
CREATE TABLE teams (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE
        CASCADE,
    name VARCHAR(100) NOT NULL,
    description TEXT,
    leader_id UUID REFERENCES users(id) ON DELETE SET NULL,
    metadata JSONB DEFAULT '{}',
    created_at TIMESTAMP DEFAULT NOW(),
    updated_at TIMESTAMP DEFAULT NOW(),
    deleted_at TIMESTAMP
);

CREATE TABLE team_members (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    team_id UUID NOT NULL REFERENCES teams(id) ON DELETE CASCADE,
    user_id UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    joined_at TIMESTAMP DEFAULT NOW(),
    UNIQUE(team_id, user_id)
);
```

Branding Tables

branding_configs

```sql
CREATE TABLE branding_configs (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE
        CASCADE,
    version INTEGER DEFAULT 1,
    is_published BOOLEAN DEFAULT FALSE,
    is_active BOOLEAN DEFAULT FALSE, -- endast en active per tenant

    -- Colors (15 färger istället för 3)
    primary_main VARCHAR(7) NOT NULL, -- hex color
    primary_light VARCHAR(7),
    primary_dark VARCHAR(7),
    secondary_main VARCHAR(7) NOT NULL,
    secondary_light VARCHAR(7),
    secondary_dark VARCHAR(7),
    accent_success VARCHAR(7),
    accent_warning VARCHAR(7),
    accent_error VARCHAR(7),
    accent_info VARCHAR(7),
    neutral_50 VARCHAR(7), -- lightest
    neutral_100 VARCHAR(7),
    neutral_300 VARCHAR(7),
    neutral_600 VARCHAR(7),
    neutral_900 VARCHAR(7), -- darkest

    -- Typography
    font_family_heading VARCHAR(100) DEFAULT 'Inter',
    font_family_body VARCHAR(100) DEFAULT 'Inter',
    font_size_config JSONB DEFAULT '{}', -- h1-h6, body, etc.

    -- Logos
    logo_main_url VARCHAR(500),
    logo_icon_url VARCHAR(500),
    logo_dark_url VARCHAR(500), -- för dark backgrounds
    favicon_url VARCHAR(500),

    -- Texts
    company_name VARCHAR(255),
    tagline VARCHAR(500),
    heading_text VARCHAR(255),
    subheading_text VARCHAR(500),

    -- Advanced
    custom_css TEXT,
    dark_mode_enabled BOOLEAN DEFAULT FALSE,
    dark_mode_config JSONB DEFAULT '{}',

    -- Metadata
```

```sql
    template_id UUID REFERENCES branding_templates(id),
    created_by UUID REFERENCES users(id),
    created_at TIMESTAMP DEFAULT NOW(),
    published_at TIMESTAMP,
    published_by UUID REFERENCES users(id),

    UNIQUE(tenant_id, version)
);

CREATE INDEX idx_branding_tenant ON branding_configs(tenant_id);
CREATE INDEX idx_branding_active ON branding_configs(tenant_id,
        is_active) WHERE is_active = TRUE;
```

branding_templates

```sql
CREATE TABLE branding_templates (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    name VARCHAR(100) NOT NULL,
    slug VARCHAR(100) UNIQUE NOT NULL,
    industry VARCHAR(100),
    description TEXT,
    config JSONB NOT NULL, -- hela branding config som JSON
    preview_image_url VARCHAR(500),
    is_system BOOLEAN DEFAULT FALSE, -- system templates kan ej
        raderas
    created_by UUID REFERENCES tenants(id), -- för custom templates
    is_public BOOLEAN DEFAULT FALSE, -- för template marketplace
    usage_count INTEGER DEFAULT 0,
    created_at TIMESTAMP DEFAULT NOW(),
    updated_at TIMESTAMP DEFAULT NOW()
);

-- System templates (8 original + 8 nya)
INSERT INTO branding_templates (name, slug, industry, config,
        is_system) VALUES
('HVAC Services', 'hvac', 'HVAC', '{"primary_main": "#FF6B35",
        ...}', TRUE),
('Electrical Services', 'electrical', 'Electrical',
        '{"primary_main": "#FFD700", ...}', TRUE),
-- ... etc
```

Audit & Logging Tables

audit_logs

```sql
CREATE TABLE audit_logs (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID REFERENCES tenants(id) ON DELETE CASCADE,
    user_id UUID REFERENCES users(id) ON DELETE SET NULL,
    action VARCHAR(100) NOT NULL, -- user.created, branding.updated,
        etc.
```

```sql
    resource_type VARCHAR(50), -- users, branding_configs, etc.
    resource_id UUID,
    changes JSONB, -- before/after values
    ip_address INET,
    user_agent TEXT,
    metadata JSONB DEFAULT '{}',
    created_at TIMESTAMP DEFAULT NOW()
);

CREATE INDEX idx_audit_tenant ON audit_logs(tenant_id);
CREATE INDEX idx_audit_user ON audit_logs(user_id);
CREATE INDEX idx_audit_action ON audit_logs(action);
CREATE INDEX idx_audit_created ON audit_logs(created_at);

-- Partition by month för performance
CREATE TABLE audit_logs_y2025m01 PARTITION OF audit_logs
    FOR VALUES FROM ('2025-01-01') TO ('2025-02-01');
```

sessions

```sql
CREATE TABLE sessions (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    token_hash VARCHAR(255) NOT NULL UNIQUE, -- JWT hash
    ip_address INET,
    user_agent TEXT,
    last_activity_at TIMESTAMP DEFAULT NOW(),
    expires_at TIMESTAMP NOT NULL,
    created_at TIMESTAMP DEFAULT NOW()
);

CREATE INDEX idx_sessions_user ON sessions(user_id);
CREATE INDEX idx_sessions_expires ON sessions(expires_at);

-- Cleanup old sessions
CREATE OR REPLACE FUNCTION cleanup_expired_sessions()
RETURNS void AS $$
BEGIN
    DELETE FROM sessions WHERE expires_at < NOW();
END;
$$ LANGUAGE plpgsql;
```

Analytics Tables

analytics_events

```sql
CREATE TABLE analytics_events (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
```

```sql
    tenant_id UUID REFERENCES tenants(id) ON DELETE CASCADE,
    user_id UUID REFERENCES users(id) ON DELETE SET NULL,
    event_type VARCHAR(100) NOT NULL, -- page_view, feature_used,
        etc.
    event_name VARCHAR(100),
    properties JSONB DEFAULT '{}',
    created_at TIMESTAMP DEFAULT NOW()
);

CREATE INDEX idx_analytics_tenant ON analytics_events(tenant_id);
CREATE INDEX idx_analytics_type ON analytics_events(event_type);
CREATE INDEX idx_analytics_created ON analytics_events(created_at);

-- Partition by month
CREATE TABLE analytics_events_y2025m01 PARTITION OF analytics_events
    FOR VALUES FROM ('2025-01-01') TO ('2025-02-01');
```

tenant_metrics (aggregated)

```sql
CREATE TABLE tenant_metrics (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE
        CASCADE,
    metric_date DATE NOT NULL,
    active_users INTEGER DEFAULT 0,
    total_logins INTEGER DEFAULT 0,
    api_calls INTEGER DEFAULT 0,
    storage_used_mb NUMERIC(10,2) DEFAULT 0,
    features_used JSONB DEFAULT '{}',
    created_at TIMESTAMP DEFAULT NOW(),
    UNIQUE(tenant_id, metric_date)
);

CREATE INDEX idx_tenant_metrics_tenant ON tenant_metrics(tenant_id);
CREATE INDEX idx_tenant_metrics_date ON tenant_metrics(metric_date);
```

File Storage Tables

files

```sql
CREATE TABLE files (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE
        CASCADE,
    uploaded_by UUID REFERENCES users(id) ON DELETE SET NULL,
    file_type VARCHAR(50), -- logo, avatar, document
    filename VARCHAR(255) NOT NULL,
    original_filename VARCHAR(255),
    mime_type VARCHAR(100),
```

```sql
    size_bytes BIGINT,
    storage_path VARCHAR(500), -- S3/storage path
    public_url VARCHAR(500),
    is_public BOOLEAN DEFAULT FALSE,
    metadata JSONB DEFAULT '{}',
    virus_scanned BOOLEAN DEFAULT FALSE,
    virus_scan_result VARCHAR(50),
    created_at TIMESTAMP DEFAULT NOW(),
    deleted_at TIMESTAMP
);

CREATE INDEX idx_files_tenant ON files(tenant_id);
CREATE INDEX idx_files_type ON files(file_type);
```

Integration Tables

webhooks

```sql
CREATE TABLE webhooks (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE
        CASCADE,
    name VARCHAR(100) NOT NULL,
    url VARCHAR(500) NOT NULL,
    events VARCHAR(100)[], -- array av event types
    secret VARCHAR(255), -- för signing
    is_active BOOLEAN DEFAULT TRUE,
    retry_count INTEGER DEFAULT 3,
    timeout_seconds INTEGER DEFAULT 30,
    created_at TIMESTAMP DEFAULT NOW(),
    updated_at TIMESTAMP DEFAULT NOW()
);

CREATE TABLE webhook_deliveries (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    webhook_id UUID NOT NULL REFERENCES webhooks(id) ON DELETE
        CASCADE,
    event_type VARCHAR(100),
    payload JSONB,
    response_status INTEGER,
    response_body TEXT,
    attempts INTEGER DEFAULT 1,
    delivered_at TIMESTAMP,
    created_at TIMESTAMP DEFAULT NOW()
);
```

api_keys

```sql
CREATE TABLE api_keys (
```

```sql
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id UUID NOT NULL REFERENCES tenants(id) ON DELETE
        CASCADE,
    user_id UUID REFERENCES users(id) ON DELETE CASCADE,
    name VARCHAR(100) NOT NULL,
    key_prefix VARCHAR(20) NOT NULL, -- första 8 chars för
        identifiering
    key_hash VARCHAR(255) NOT NULL UNIQUE,
    permissions VARCHAR(100)[], -- scoped permissions
    last_used_at TIMESTAMP,
    expires_at TIMESTAMP,
    is_active BOOLEAN DEFAULT TRUE,
    created_at TIMESTAMP DEFAULT NOW(),
    revoked_at TIMESTAMP
);

CREATE INDEX idx_api_keys_tenant ON api_keys(tenant_id);
CREATE INDEX idx_api_keys_hash ON api_keys(key_hash);
```

---

6. API Endpoint Specifikationer

Base URL

```
Production: https://api.unicorn.app/v1
Staging: https://api-staging.unicorn.app/v1
```

Authentication

```
Header: Authorization: Bearer <JWT_TOKEN>
Alternative: X-API-Key: <API_KEY>

Tenant Context:
Header: X-Tenant-ID: <tenant_id>
(automatiskt från JWT claim om möjligt)
```

Response Format

```json
{
    "success": true,
    "data": { ... },
    "meta": {
        "timestamp": "2025-12-26T10:00:00Z",
        "request_id": "uuid"
    }
}

// Error Response
```

```
{
    "success": false,
    "error": {
        "code": "VALIDATION_ERROR",
        "message": "Invalid input",
        "details": [ ... ]
    },
    "meta": { ... }
}
```

Tenant Management

GET /tenants

```
Description: List all tenants (system admin only)
Query Params:
  - page: integer (default: 1)
  - per_page: integer (default: 20, max: 100)
  - status: string (active, suspended, cancelled)
  - search: string (name or slug)
  - sort: string (created_at, name, status)
  - order: string (asc, desc)

Response:
{
    "data": [
        {
            "id": "uuid",
            "name": "Acme Services AB",
            "slug": "acme-services",
            "status": "active",
            "tier": "professional",
            "user_count": 15,
            "max_users": 25,
            "created_at": "2025-01-15T10:00:00Z"
        }
    ],
    "meta": {
        "total": 150,
        "page": 1,
        "per_page": 20,
        "total_pages": 8
    }
}
```

GET /tenants/:id

```
Description: Get tenant details
```

```
Permissions: system admin or tenant owner

Response:
{
    "data": {
        "id": "uuid",
        "name": "Acme Services AB",
        "slug": "acme-services",
        "subdomain": "acme.unicorn.app",
        "custom_domain": null,
        "status": "active",
        "tier": "professional",
        "max_users": 25,
        "features": {
            "custom_branding": true,
            "api_access": true,
            "sso": false
        },
        "users": {
            "count": 15,
            "active": 12
        },
        "created_at": "2025-01-15T10:00:00Z",
        "updated_at": "2025-12-20T15:30:00Z"
    }
}
```

POST /tenants

```
Description: Create new tenant (system admin only)
Body:
{
    "name": "Acme Services AB",
    "slug": "acme-services",
    "tier": "professional",
    "max_users": 25,
    "owner": {
        "email": "owner@acme.se",
        "first_name": "John",
        "last_name": "Doe",
        "phone": "+46701234567"
    }
}

Response: 201 Created
{
    "data": {
        "id": "uuid",
```

```
        "name": "Acme Services AB",
        "owner": { ... },
        "credentials": {
            "email": "owner@acme.se",
            "temporary_password": "generated_password"
        }
    }
}
```

PATCH /tenants/:id

```
Description: Update tenant
Permissions: system admin or tenant owner
Body:
{
    "name": "Acme Services AB Updated",
    "status": "active",
    "max_users": 30
}

Response: 200 OK
```

DELETE /tenants/:id

```
Description: Delete tenant (soft delete)
Permissions: system admin only
Response: 204 No Content
```

User Management

GET /users

```
Description: List users in tenant
Query Params:
  - page, per_page, search, sort, order (same as tenants)
  - role: string (owner, admin, user)
  - status: string (active, inactive, suspended)
  - team_id: uuid

Response:
{
    "data": [
        {
            "id": "uuid",
            "email": "user@company.com",
            "first_name": "Jane",
            "last_name": "Smith",
            "phone": "+46701234567",
```

```
            "status": "active",
            "roles": ["admin"],
            "teams": ["Installation Team"],
            "last_login_at": "2025-12-25T14:30:00Z",
            "created_at": "2025-01-20T10:00:00Z"
        }
    ],
    "meta": { ... }
}
```

GET /users/:id

```
Description: Get user details
Permissions: self, admins

Response:
{
    "data": {
        "id": "uuid",
        "email": "user@company.com",
        "first_name": "Jane",
        "last_name": "Smith",
        "phone": "+46701234567",
        "avatar_url":
"https://pbs.twimg.com/profile_images/1086032558629011456/JuUbBFOI_4(

        "locale": "sv-SE",
        "timezone": "Europe/Stockholm",
        "status": "active",
        "roles": [
            {
                "id": "uuid",
                "name": "Admin",
                "permissions": [...]
            }
        ],
        "teams": [ ... ],
        "two_factor_enabled": true,
        "last_login_at": "2025-12-25T14:30:00Z",
        "created_at": "2025-01-20T10:00:00Z"
    }
}
```

POST /users

```
Description: Create new user
Permissions: admin+
```

```
Body:
{
    "email": "newuser@company.com",
    "first_name": "John",
    "last_name": "Doe",
    "phone": "+46701234567",
    "role_ids": ["uuid"],
    "team_ids": ["uuid"],
    "send_welcome_email": true
}

Response: 201 Created
{
    "data": {
        "id": "uuid",
        "email": "newuser@company.com",
        "temporary_password": "generated" // om send_welcome_email =
false
    }
}
```

POST /users/bulk-import

```
Description: Bulk import users from CSV
Permissions: admin+
Body: multipart/form-data
  - file: CSV file
  - send_welcome_emails: boolean

CSV Format:
email,first_name,last_name,phone,role,team

Response: 202 Accepted
{
    "data": {
        "job_id": "uuid",
        "status": "processing"
    }
}

// Get job status
GET /users/bulk-import/:job_id
```

PATCH /users/:id

```
Description: Update user
Permissions: self (limited), admins (full)
Body:
```

```
{
    "first_name": "Jane",
    "phone": "+46709876543",
    "role_ids": ["uuid"], // admin only
    "status": "inactive" // admin only
}

Response: 200 OK
```

DELETE /users/:id

```
Description: Delete user (soft delete)
Permissions: admin+
Response: 204 No Content
```

POST /users/:id/roles

```
Description: Assign role to user
Permissions: owner, admin (depending on target role)
Body:
{
    "role_id": "uuid",
    "expires_at": "2025-12-31T23:59:59Z" // optional
}

Response: 200 OK
```

DELETE /users/:id/roles/:role_id

```
Description: Remove role from user
Permissions: owner, admin
Response: 204 No Content
```

Branding Management

GET /branding

```
Description: Get active branding for tenant
Permissions: authenticated users
Response:
{
    "data": {
        "id": "uuid",
        "version": 3,
        "is_active": true,
        "colors": {
            "primary": {
                "main": "#FF6B35",
```

```
                "light": "#FF8F66",
                "dark": "#CC5529"
            },
            "secondary": { ... },
            "accent": { ... },
            "neutral": { ... }
        },
        "typography": {
            "heading": {
                "family": "Montserrat",
                "sizes": { "h1": "32px", ... }
            },
            "body": { ... }
        },
        "logos": {
            "main":
"https://i.pinimg.com/736x/53/32/da/5332da739c9d8b8765245f68cfdab88f.

            "icon":
"https://upload.wikimedia.org/wikipedia/commons/7/7c/ACME%E2%80%93pro
icon.png",
            "favicon":
"https://media.licdn.com/dms/image/v2/C4E0BAQF0U846FN-wUg/company-
logo_200_200/company-
logo_200_200/0/1630607140532/acmehrservices_logo?
e=2147483647&v=beta&t=r39o33M2ywxLFQ-kCzIASKIhKwx16KQSx4oGHMeYLFQ"
        },
        "texts": {
            "company_name": "Acme Services",
            "tagline": "Din pålitliga partner",
            "heading": "Välkommen",
            "subheading": "Vi är här för att hjälpa"
        },
        "template": {
            "id": "uuid",
            "name": "HVAC Services"
        },
        "published_at": "2025-12-20T10:00:00Z"
    }
}
```


GET /branding/versions

```
Description: List all branding versions
Permissions: owner, admin
Response:
{
```

```
    "data": [
        {
            "id": "uuid",
            "version": 3,
            "is_published": true,
            "is_active": true,
            "created_by": {
                "id": "uuid",
                "name": "Jane Smith"
            },
            "created_at": "2025-12-20T09:00:00Z",
            "published_at": "2025-12-20T10:00:00Z"
        },
        {
            "id": "uuid",
            "version": 2,
            "is_published": false, // draft
            "is_active": false,
            "created_at": "2025-12-19T15:00:00Z"
        }
    ]
}
```

GET /branding/versions/:id

```
Description: Get specific branding version
Permissions: owner, admin
Response: Same as GET /branding but for specific version
```

POST /branding

```
Description: Create new branding config (draft)
Permissions: owner, admin
Body:
{
    "colors": {
        "primary_main": "#FF6B35",
        "primary_light": "#FF8F66",
        // ... all 15 colors
    },
    "typography": {
        "font_family_heading": "Montserrat",
        "font_family_body": "Inter",
        "font_sizes": { ... }
    },
    "logos": {
        "main_url":
"https://d3jmn01ri1fzgl.cloudfront.net/photoadking/static_assets/web/
```

```
images/key_feature/logo/website-logo-templates.webp",
        "icon_url":
"https://upload.wikimedia.org/wikipedia/commons/6/6e/Acme-corp.png",
        "favicon_url":
"https://upload.wikimedia.org/wikipedia/commons/thumb/1/16/ACME%E2%80
icon.svg/330px-ACME%E2%80%93protocol-icon.svg.png"
    },
    "texts": {
        "company_name": "Acme Services",
        "tagline": "Din pålitliga partner",
        "heading": "Välkommen",
        "subheading": "Vi är här för att hjälpa"
    },
    "custom_css": "/* optional */",
    "template_id": "uuid" // optional, för att applicera template
}

Response: 201 Created
{
    "data": {
        "id": "uuid",
        "version": 4,
        "is_published": false,
        "preview_url":
"https://upload.wikimedia.org/wikipedia/en/thumb/9/9a/Techtronic_Indu
Techtronic_Industries_logo.png"
    }
}
```

PATCH /branding/:id

```
Description: Update draft branding
Permissions: owner, admin
Body: Same as POST (partial updates allowed)
Response: 200 OK
```

POST /branding/:id/publish

```
Description: Publish branding (make active)
Permissions: owner
Body:
{
    "scheduled_at": "2025-12-31T00:00:00Z" // optional
}

Response: 200 OK
{
```

```
    "data": {
        "id": "uuid",
        "is_active": true,
        "published_at": "2025-12-26T10:00:00Z"
    }
}
```

POST /branding/:id/unpublish

```
Description: Unpublish branding (revert to previous)
Permissions: owner
Response: 200 OK
```

DELETE /branding/:id

```
Description: Delete draft branding
Permissions: owner, admin
Note: Cannot delete published/active branding
Response: 204 No Content
```

Branding Templates

GET /branding/templates

```
Description: List available templates
Permissions: authenticated
Query:
  - industry: string
  - is_system: boolean
  - search: string

Response:
{
    "data": [
        {
            "id": "uuid",
            "name": "HVAC Services",
            "slug": "hvac",
            "industry": "HVAC",
            "description": "Professionell mall för värmepump- och
ventilationsföretag",
            "preview_image_url":
"https://upload.wikimedia.org/wikipedia/commons/9/9f/HVAC_system_diag

            "usage_count": 45,
            "is_system": true
        }
    ]
```

```
}
```

GET /branding/templates/:id

```
Description: Get template details with full config
Response:
{
    "data": {
        "id": "uuid",
        "name": "HVAC Services",
        "config": {
            "colors": { ... },
            "typography": { ... }
        },
        "preview_image_url": "https://visme.co/blog/wp-
content/uploads/2016/09/11.jpg"
    }
}
```

POST /branding/templates/:id/apply

```
Description: Apply template to tenant (creates new branding config)
Permissions: owner, admin
Response: 201 Created (new branding config)
```

POST /branding/templates

```
Description: Create custom template from current branding
Permissions: owner
Body:
{
    "name": "My Custom Template",
    "description": "Template for my organization",
    "is_public": false // share in marketplace
}

Response: 201 Created
```

File Management

POST /files/upload

```
Description: Upload file (logo, avatar, etc.)
Permissions: authenticated
Body: multipart/form-data
  - file: binary
  - file_type: string (logo, avatar, document)
  - is_public: boolean
```

```
Validation:
  - Max size: 5MB för loggor, 2MB för avatars
  - Allowed types: image/png, image/jpeg, image/svg+xml, image/webp
  - Virus scanning before storage
  - Image optimization (resize, compress)

Response: 201 Created
{
    "data": {
        "id": "uuid",
        "filename": "logo.png",
        "public_url":
"https://upload.wikimedia.org/wikipedia/commons/thumb/a/a6/Name.com_l
Name.com_Logo_2023.svg.png",
        "size_bytes": 125678,
        "mime_type": "image/png"
    }
}
```

GET /files/:id

```
Description: Get file metadata
Response: File metadata
```

DELETE /files/:id

```
Description: Delete file
Permissions: owner, admin, uploader
Response: 204 No Content
```

Analytics

GET /analytics/dashboard

```
Description: Get dashboard analytics
Permissions: owner (tenant metrics), system admin (all tenants)
Query:
  - start_date: date
  - end_date: date
  - metrics: array (users, logins, api_calls, storage)

Response:
{
    "data": {
        "period": {
            "start": "2025-12-01",
```

```
            "end": "2025-12-26"
        },
        "metrics": {
            "users": {
                "total": 25,
                "active": 18,
                "new": 3,
                "trend": "+12%"
            },
            "logins": {
                "total": 450,
                "daily_average": 18,
                "trend": "+5%"
            },
            "api_calls": {
                "total": 12500,
                "by_endpoint": { ... },
                "trend": "+23%"
            },
            "storage": {
                "used_mb": 1250,
                "limit_mb": 5000,
                "percentage": 25
            }
        },
        "charts": {
            "logins_by_day": [ ... ],
            "feature_usage": [ ... ]
        }
    }
}
```

GET /analytics/users/:id/activity

```
Description: Get user activity log
Permissions: admins, self (limited)
Response:
{
    "data": [
        {
            "timestamp": "2025-12-26T10:30:00Z",
            "action": "branding.updated",
            "details": { ... }
        }
    ]
}
```

Audit Logs

GET /audit-logs

```
Description: Get audit logs
Permissions: owner, admin
Query:
  - start_date, end_date: date range
  - user_id: filter by user
  - action: filter by action type
  - resource_type: filter by resource
  - page, per_page

Response:
{
    "data": [
        {
            "id": "uuid",
            "timestamp": "2025-12-26T10:30:00Z",
            "user": {
                "id": "uuid",
                "name": "Jane Smith",
                "email": "jane@company.com"
            },
            "action": "user.created",
            "resource_type": "users",
            "resource_id": "uuid",
            "changes": {
                "before": null,
                "after": { ... }
            },
            "ip_address": "192.168.1.100",
            "user_agent": "Mozilla/5.0..."
        }
    ],
    "meta": { ... }
}
```

GET /audit-logs/export

```
Description: Export audit logs to CSV
Permissions: owner
Query: Same filters as GET
Response: CSV file download
```

Webhooks

GET /webhooks

```
Description: List webhooks
```

```
Permissions: owner, admin
Response:
{
    "data": [
        {
            "id": "uuid",
            "name": "User Creation Notifier",
            "url": "https://external.com/webhook",
            "events": ["user.created", "user.deleted"],
            "is_active": true,
            "last_delivery_at": "2025-12-26T09:00:00Z",
            "success_rate": 0.98
        }
    ]
}
```

POST /webhooks

```
Description: Create webhook
Permissions: owner
Body:
{
    "name": "User Creation Notifier",
    "url": "https://external.com/webhook",
    "events": ["user.created", "user.deleted"],
    "secret": "optional_signing_secret"
}

Response: 201 Created
```

GET /webhooks/:id/deliveries

```
Description: Get webhook delivery history
Response:
{
    "data": [
        {
            "id": "uuid",
            "event_type": "user.created",
            "status": "success",
            "response_status": 200,
            "attempts": 1,
            "delivered_at": "2025-12-26T09:00:00Z"
        }
    ]
}
```

POST /webhooks/:id/test

```
Description: Test webhook with sample payload
Response: Delivery result
```

API Rate Limits

```
Tier-based limits:
- Basic: 1000 requests/hour
- Professional: 5000 requests/hour
- Enterprise: 25000 requests/hour

Headers in response:
X-RateLimit-Limit: 5000
X-RateLimit-Remaining: 4850
X-RateLimit-Reset: 1640520000

429 Too Many Requests när limit nådd
```

---

7. Säkerhetsbästa Praxis

7.1 Authentication & Authorization

Password Policy

```
Requirements:
- Minst 12 tecken
- Mix av stora/små bokstäver, siffror, specialtecken
- Inte tidigare använda lösenord (spara hash av senaste 5)
- Inte vanliga lösenord (check mot haveibeenpwned.com API)
- Obligatorisk ändring var 90:e dag för admins (optional för users)
- Account lockout efter 5 misslyckade försök (30 min lockout)
```

Two-Factor Authentication

```
Implementation:
- TOTP (Google Authenticator, Authy) som primär metod
- SMS backup (för användare utan smartphone)
- Recovery codes (10st, single-use) vid 2FA enrollment
- Obligatorisk 2FA för owners och admins
- Optional för users (men rekommenderat)
```

Session Management

```
Configuration:
- JWT tokens med kort livstid (15 min access token, 7 day refresh
token)
- Refresh token rotation vid varje användning
- Secure, HttpOnly, SameSite cookies
- Session timeout efter 30 min inaktivitet
```

```
- Max 3 concurrent sessions per användare
- Session revocation vid lösenordsändring eller role change
```

SSO Integration

```
Standards:
- SAML 2.0 för enterprise customers
- OAuth 2.0 / OpenID Connect
- Just-In-Time (JIT) user provisioning
- Attribute mapping (email, name, role)
- IdP-initiated och SP-initiated flows
```

7.2 Data Security

Encryption

```
At Rest:
- AES-256 encryption för databas (PostgreSQL TDE)
- Encrypted file storage (S3 server-side encryption)
- Separate encryption keys per tenant (KMS)

In Transit:
- TLS 1.3 för all kommunikation
- Certificate pinning för mobile apps
- HSTS headers
- Perfect Forward Secrecy (PFS)
```

Tenant Isolation

```
Database Level:
- Row-Level Security (RLS) policies
- Separate database schema per tenant (för enterprise)
- Connection pooling med tenant context
- Query auditing för cross-tenant access attempts

Application Level:
- Middleware för tenant context validation
- API request signing för inter-service communication
- Tenant ID i alla audit logs
```

Data Sanitization

```
Input Validation:
- Whitelist-based validation
- Parameterized queries (no SQL injection)
- HTML/JS sanitization för användarinput
- File upload validation (type, size, content)
- Rate limiting på alla endpoints

Output Encoding:
```

```
- Context-aware encoding (HTML, JS, URL, CSS)
- Content Security Policy (CSP) headers
- X-Content-Type-Options: nosniff
- X-Frame-Options: DENY (förhindra clickjacking)
```

7.3 API Security

Authentication

```
Methods:
- JWT Bearer tokens (standard)
- API Keys med scoped permissions (för M2M)
- OAuth 2.0 client credentials flow

Token Security:
- Short-lived tokens
- Token revocation lists
- Refresh token rotation
- Secure token storage (never in localStorage, use httpOnly cookies)
```

Authorization

```
Implementation:
- Permission-based access control
- Validate tenant context för alla requests
- Check permissions BEFORE executing business logic
- Fail closed (deny by default)
```

Rate Limiting

```
Strategy:
- Token bucket algorithm
- Per tenant + per user limits
- Different limits för read vs write operations
- Stricter limits för sensitive endpoints (auth, file upload)
- Distributed rate limiting (Redis)

Limits:
- Auth endpoints: 5 req/min per IP
- File upload: 10 req/hour per user
- Standard API: 1000-25000 req/hour per tenant (tier-based)
- Webhook delivery: 100 req/min per webhook
```

API Versioning

```
Strategy:
- URI versioning (/v1/, /v2/)
- Semantic versioning
- Deprecation warnings (6 months notice)
- Sunset headers för deprecated versions
```

7.4 File Upload Security

Validation

```
Checks:
1. File type validation (MIME type + extension + magic bytes)
2. File size limits (enforced at multiple levels)
3. Filename sanitization (remove path traversal attempts)
4. Virus scanning (ClamAV eller cloud service)
5. Image reprocessing (förhindra steganography attacks)
6. Metadata stripping (EXIF data removal)
```

Storage

```
Best Practices:
- Store filer outside webroot
- Generate random filenames (förhindra enumeration)
- Separate CDN för public assets
- Signed URLs för private files (time-limited access)
- Regular backups med versioning
- Automatic cleanup av gamla filer
```

Logo-Specific Security

```
Additional Checks:
- Max resolution (2000x2000px)
- Resize och optimize automatiskt
- Convert to safe format (PNG/JPEG)
- Validate aspect ratio (förhindra extrem format)
- Generate thumbnails för preview
```

7.5 Compliance

GDPR

```
Requirements:
- Data processing agreements med tenants
- Privacy policy och terms of service
- Cookie consent management
- Right to access (data export för users)
- Right to erasure (permanent deletion, not just soft delete)
- Right to portability (standard format export)
- Data breach notification (inom 72h)
- Data retention policies
- Data minimization (endast nödvändig data)

Implementation:
- Audit logs för all data access
- Anonymization för analytics
- Secure data deletion (överwrite, not just DELETE)
```

```
- Regular compliance audits
```

ISO 27001 / SOC 2

```
Controls:
- Information security policies
- Risk assessment process
- Incident response plan
- Business continuity plan
- Vendor management
- Regular security training
- Penetration testing (annually)
- Vulnerability scanning (monthly)
```

7.6 Monitoring & Incident Response

Security Monitoring

```
Alerts:
- Failed login attempts (>5 per user/hour)
- Privilege escalation attempts
- Unusual API usage patterns
- Cross-tenant access attempts
- Mass data exports
- Suspicious file uploads
- Rate limit exceeded frequently

Tools:
- SIEM integration (Splunk, ELK)
- Real-time alerting (PagerDuty, Slack)
- Automated responses (temporary account locks)
```

Incident Response Plan

```
Phases:
1. Detection & Analysis
   - Automated detection
   - User reports
   - Security researcher disclosures

2. Containment
   - Isolate affected systems
   - Revoke compromised credentials
   - Block malicious IPs

3. Eradication
   - Remove malicious code/access
   - Patch vulnerabilities
   - Reset passwords
```

```
4. Recovery
   - Restore from backups
   - Monitor för re-infection
   - Gradual service restoration

5. Post-Incident
   - Root cause analysis
   - Update security controls
   - Documentation
   - User communication
```

Backup & Disaster Recovery

```
Strategy:
- Automated daily backups (full + incremental)
- Off-site backup storage (multiple regions)
- Encrypted backups
- Regular restore testing (monthly)
- Point-in-time recovery (PITR) capability
- RTO: 4 hours, RPO: 1 hour
- Disaster recovery playbook
```

---

8. UX/UI Rekommendationer

8.1 Navigation & Information Architecture

Huvudnavigering

```
Struktur (för System Dashboard):
1. 🏠 Dashboard (overview, analytics)
2. 🎨 Branding (customization, templates)
3. 👥 Användare (list, roles, teams)
4. ⚙️ Inställningar (tenant settings, preferences)
5. 📊 Rapporter (analytics, audit logs)
6. 🔗 Integrationer (webhooks, API keys, SSO)
7. 📖 Hjälp & Support

Visibility baserat på role:
- Owner: Alla menyer
- Admin: Dashboard, Branding (view), Användare, Rapporter, Hjälp
- Manager: Dashboard, Användare (limited), Rapporter (limited),
Hjälp
- User: Dashboard (basic), Inställningar (egen profil), Hjälp
```

Breadcrumbs & Context

```
Visa alltid:
```

```
- Var användaren befinner sig (breadcrumbs)
- Vilken tenant som är active (för multi-tenant admins)
- Osparade ändringar warning
- Last saved timestamp
```

8.2 Branding Interface

Color Picker

```
Features:
- Visual color picker (wheel + sliders)
- HEX, RGB, HSL input
- Color palette suggestions (from logo)
- Accessibility checker (WCAG AA/AAA contrast)
- Recent colors history
- Save custom palettes
- Import från andra brand guidelines
```

Live Preview

```
Components to preview:
- Dashboard header/sidebar
- Form elements (buttons, inputs, checkboxes)
- Data tables
- Cards och panels
- Alerts och notifications
- Charts och graphs
- Mobile view (responsive preview)

Preview modes:
- Light mode
- Dark mode (om enabled)
- High contrast mode
```

Template Selector

```
UI:
- Grid layout med preview images
- Industry filters
- Search by name
- Hover för quick preview
- Click för detailed view
- "Apply" button med confirmation
- "Customize" button för att applicera och sedan ändra
```

8.3 User Management Interface

User List

```
Columns:
- Avatar + Name
- Email
- Role(s) badges
- Team(s) tags
- Status (active, inactive, suspended)
- Last Login
- Actions menu

Features:
- Multi-column sorting
- Advanced filters (drawer/sidebar)
- Search (fuzzy search on name, email, phone)
- Bulk actions (select multiple users)
- Export to CSV
- Column visibility toggle
- Saved filter presets
```

User Form (Create/Edit)

```
Sections:
1. Personlig Information
   - Förnamn, Efternamn
   - Email (unique validation)
   - Telefon (format validation)
   - Avatar upload

2. Åtkomst
   - Roller (multi-select med förklaring av varje roll)
   - Teams (multi-select)
   - Status (active/inactive)

3. Inställningar
   - Språk
   - Timezone
   - Notifikationer

4. Säkerhet (för admins)
   - Force password reset
   - Require 2FA
   - Set expiration date

Validation:
- Real-time validation
- Clear error messages
- Success confirmation
- Option to "Save and create another"
```

Bulk Import

```
Wizard steps:
1. Download CSV template
2. Upload CSV file
3. Map columns (om headers inte matchar)
4. Validate data (show errors before import)
5. Review summary (X users, Y errors)
6. Confirm import
7. Progress bar med status
8. Summary report (success/failed)
```

8.4 Role Management

Role Builder

```
UI för custom roles:
1. Role namn och beskrivning
2. Permission groups (accordion eller tabs)
   - Branding (view, edit, publish)
   - Användare (view, create, edit, delete, assign_roles)
   - Rapporter (view, export)
   - Inställningar (view, edit)
   - API (access, manage_keys)
   - Etc.
3. Checkbox för varje permission
4. "Select all" / "Select none" för varje grupp
5. Preview: "Användare med denna roll kan..."
6. Test mode: "Logga in som denna roll" (för testing)
```

Role Assignment

```
Interface:
- Drag-and-drop från available roles till user
- Click-to-add med autocomplete
- Visual representation av roller (badges, färger)
- Hover för att se permissions
- Temporary role elevation: set expiration date
```

8.5 Dashboard & Analytics

Dashboard Layout

```
Widgets (grid layout, drag-to-reorder):
1. Quick Stats
   - Total användare, Active users, New users (this month)
   - API calls, Storage used

2. Charts
   - User logins över tid (line chart)
   - Feature usage (bar chart)
```

```
   - User distribution per role (pie chart)

3. Recent Activity
   - Latest user creations
   - Latest branding changes
   - Latest logins

4. Alerts & Notifications
   - Approaching user limit
   - Inactive users (30+ days)
   - Failed login attempts

5. Quick Actions
   - Create user
   - Edit branding
   - View audit log
   - Download reports
```

Responsive Design

```
Breakpoints:
- Desktop (1200px+): Full layout med sidebar
- Tablet (768-1199px): Collapsed sidebar, stackable widgets
- Mobile (<768px): Hamburger menu, single column, priority content

Mobile optimizations:
- Touch-friendly buttons (min 44x44px)
- Swipe gestures
- Bottom navigation (för frequent actions)
- Lazy loading för tables
```

8.6 Accessibility (WCAG 2.1 AA)

Keyboard Navigation

```
- Tab order logisk och sekvensiell
- Skip to main content link
- Focus indicators (tydliga)
- Keyboard shortcuts (med dokumentation)
- Escape to close modals/dropdowns
```

Screen Reader Support

```
- Semantic HTML (proper heading hierarchy)
- ARIA labels för ikoner och buttons
- ARIA live regions för dynamiskt innehåll
- Alt text för alla bilder
- Form labels och error associations
```

Visual Accessibility

```
- Minst 4.5:1 contrast ratio för text (WCAG AA)
- 3:1 för stora texter och UI components
- Färgblindhetsvänlig palette
- Inte endast färg för att förmedla information
- Resizable text (upp till 200%)
- No flashing content (epilepsi risk)
```

8.7 Feedback & Validation

Loading States

```
- Skeleton screens för initial load
- Spinners för actions
- Progress bars för långsamma operationer (upload, import)
- Optimistic updates där möjligt
- Timeout warnings för långsamma requests
```

Success States

```
- Toast notifications (auto-dismiss efter 5s)
- Success modals för kritiska actions
- Checkmark animations
- Redirect med success message
```

Error States

```
- Inline validation errors (real-time)
- Clear error messages (vad gick fel + hur fixa)
- Error summary at top of form
- Retry buttons för failed operations
- Support contact för unrecoverable errors
```

Empty States

```
- Friendly illustrations
- Descriptive text
- Call-to-action button (Create first user, Apply template)
- Help links eller tips
```

---

9. Skalbarhet & Performance

9.1 Database Optimization

Indexing Strategy

```
-- Tenant-based queries (mest common)
```

```sql
CREATE INDEX idx_users_tenant_status ON users(tenant_id, status)
        WHERE deleted_at IS NULL;
CREATE INDEX idx_branding_tenant_active ON
        branding_configs(tenant_id, is_active) WHERE is_active =
        TRUE;


-- Search queries
CREATE INDEX idx_users_search ON users USING
        gin(to_tsvector('swedish', first_name || ' ' || last_name ||
        ' ' || email));


-- Audit log queries (time-based)
CREATE INDEX idx_audit_tenant_created ON audit_logs(tenant_id,
        created_at DESC);


-- Performance monitoring
EXPLAIN ANALYZE SELECT * FROM users WHERE tenant_id = 'uuid' AND
        status = 'active';
```

Partitioning

```sql
-- Partition audit_logs and analytics_events by month
CREATE TABLE audit_logs (
    ...
) PARTITION BY RANGE (created_at);


-- Create partitions dynamically
CREATE TABLE audit_logs_y2025m01 PARTITION OF audit_logs
    FOR VALUES FROM ('2025-01-01') TO ('2025-02-01');


-- Automated partition creation (cronjob eller function)
CREATE OR REPLACE FUNCTION create_next_month_partition()
RETURNS void AS $$
DECLARE
    next_month date := date_trunc('month', CURRENT_DATE + interval
        '1 month');
    partition_name text := 'audit_logs_y' || to_char(next_month,
        'YYYY') || 'm' || to_char(next_month, 'MM');
BEGIN
    EXECUTE format('CREATE TABLE IF NOT EXISTS %I PARTITION OF
        audit_logs FOR VALUES FROM (%L) TO (%L)',
        partition_name,
        next_month,
        next_month + interval '1 month'
    );
END;
$$ LANGUAGE plpgsql;
```

Connection Pooling

```
Configuration (PgBouncer eller application-level):
- Pool mode: Transaction (för stateless apps)
- Max connections per tenant: 10-20
```

```
- Connection timeout: 30s
- Query timeout: 60s
- Statement timeout: 30s

Monitoring:
- Active connections per tenant
- Connection wait time
- Query performance (slow query log)
```

9.2 Caching Strategy

Application Cache (Redis)

```
Cache layers:
1. Branding config (key: branding:tenant:{id}:active, TTL: 1 hour)
2. User permissions (key: user:{id}:permissions, TTL: 15 min)
3. Tenant metadata (key: tenant:{id}, TTL: 1 hour)
4. Template list (key: templates:all, TTL: 24 hours)
5. API rate limits (key: ratelimit:{tenant}:{endpoint}, TTL: 1 hour)

Invalidation:
- Explicit invalidation på updates
- Tag-based invalidation (flush alla tenant-related keys)
- Background refresh för hot data
```

CDN Caching

```
CloudFront eller Cloudflare:
- Static assets (JS, CSS, images): 1 year cache
- Logo files: 1 week cache (med versioned URLs)
- API responses (GET only): 5-60 seconds för vissa endpoints
- Cache-Control headers
- Vary header för multi-tenant (X-Tenant-ID)
```

Browser Caching

```
Headers:
- Static assets: Cache-Control: public, max-age=31536000, immutable
- API responses: Cache-Control: private, max-age=300
- No cache för sensitive data: Cache-Control: no-store, must-
revalidate
```

9.3 Asynchronous Processing

Job Queue (Sidekiq, Bull, Celery)

```
Use cases:
- Welcome email sending
- Bulk user import
```

```
- Audit log processing
- Analytics aggregation
- Webhook delivery
- Image processing (resize, optimize)
- Report generation

Configuration:
- Priority queues (critical, high, normal, low)
- Retry logic med exponential backoff
- Dead letter queue för failed jobs
- Job TTL (expire old jobs)
- Concurrency per queue
```

Event-Driven Architecture

```
Events:
- tenant.created → provision resources, send welcome email
- user.created → send welcome email, create audit log
- branding.updated → invalidate cache, trigger webhook
- user.deleted → cleanup resources, update analytics

Implementation:
- Event bus (RabbitMQ, Kafka, AWS EventBridge)
- Event sourcing för audit trail
- CQRS pattern för analytics (separate read/write models)
```

9.4 Horizontal Scaling

Application Servers

```
- Stateless application design
- Load balancer (Nginx, ALB, Traefik)
- Auto-scaling based på CPU/memory
- Health checks för load balancer
- Graceful shutdown (finish current requests)
- Session affinity inte nödvändigt (JWT-based auth)
```

Database Scaling

```
Read Replicas:
- 1-3 read replicas för read-heavy workloads
- Connection pooler routes read-only queries to replicas
- Eventual consistency är OK för analytics

Sharding (för extremt stora installationer):
- Shard by tenant_id
- Tenant-aware routing layer
- Cross-shard queries minimeras
```

Microservices (future)

```
Service boundaries:
- Auth Service (authentication, authorization)
- Tenant Service (tenant management, branding)
- User Service (user CRUD, teams)
- Analytics Service (metrics, reporting)
- Notification Service (email, SMS, webhooks)
- File Service (upload, storage, CDN)

Communication:
- Sync: REST or gRPC mellan services
- Async: Message queue för events
- Service mesh (Istio, Linkerd) för resilience
```

9.5 Performance Monitoring

Metrics to Track

```
Application:
- Request rate (req/s)
- Response time (p50, p95, p99)
- Error rate
- Apdex score

Database:
- Query time (slow query log)
- Connection pool utilization
- Cache hit rate
- Replication lag

Infrastructure:
- CPU, memory, disk usage
- Network throughput
- Auto-scaling events

Business:
- Active users per tenant
- Feature adoption
- API usage per tenant
- Revenue per tenant (unit economics)
```

Tools

```
- APM: New Relic, Datadog, Elastic APM
- Logging: ELK stack (Elasticsearch, Logstash, Kibana)
- Metrics: Prometheus + Grafana
- Tracing: Jaeger, Zipkin
- Alerts: PagerDuty, Opsgenie
```

Performance Budgets

```
Targets:
- Page load time: < 2s (75th percentile)
- API response time: < 200ms (95th percentile)
- Time to Interactive: < 3s
- Database query time: < 50ms (95th percentile)
- Uptime: 99.9% (8.76 hours downtime/year)
```

---

10. Implementeringsplan (Roadmap)

Fas 1: MVP (8-10 veckor)

Vecka 1-2: Foundation & Setup - Projektstruktur och development environment - Database schema implementation (core tables) - Authentication system (email/password, JWT) - Tenant context middleware - Basic API structure och error handling

Vecka 3-4: User Management - User CRUD endpoints - Role assignment (3 standard roles: owner, admin, user) - User list UI med filtering och search - User form (create/edit) - Basic audit logging

Vecka 5-6: Branding System - Branding config CRUD (3 colors + logo + texts) - 8 industry templates implementation - Template selector UI - Branding form med color pickers - File upload för logos (basic validation)

Vecka 7-8: Live Preview & Integration - Live preview component (dashboard, forms, buttons) - Dynamic CSS variable generation - Apply template functionality - Integration mellan branding och main application - Responsive design för mobile

Vecka 9-10: Testing & Polish - E2E testing (Playwright, Cypress) - Security testing (basic penetration testing) - Performance optimization - Bug fixes och UI polish - Documentation (API docs, user guide)

MVP Features: ✅ User management (create, edit, delete, list) ✅ 3 standard roles (owner, admin, user) ✅ Branding (3 colors + logo + texts) ✅ 8 industry templates ✅ Live preview (basic components) ✅ Basic audit logging ✅ Responsive design

Fas 2: Enhanced Security & UX (4-6 veckor)

Vecka 1-2: Advanced Security - Two-factor authentication (TOTP) - Session management (concurrent session control) - Enhanced password policy - Account lockout mechanism - Improved file upload security (virus scanning, validation) - Rate limiting implementation

Vecka 3-4: Improved UX - Bulk user import (CSV) - User notifications (welcome email, password reset) - Enhanced live preview (more components, mobile preview) - Drag-and-drop file upload - Better error handling och feedback - Empty states och loading states

Vecka 5-6: Branding Extensions - Extended color palette (15 colors) - Typography system (font selection) - Branding versioning (drafts, publish/unpublish) - A/B testing setup (infrastructure) - Accessibility checker (contrast ratios)

Fas 2 Features: ✅ 2FA ✅ Bulk user import ✅ User notifications ✅ Enhanced branding (15 colors, typography) ✅ Branding versioning ✅ Better security (rate limiting, enhanced validation)

Fas 3: Analytics & Reporting (3-4 veckor)

Vecka 1-2: Analytics Infrastructure - Analytics event tracking - Aggregated metrics tables - Dashboard metrics API endpoints - Basic dashboard UI (charts med Plotly eller Chart.js) - Export reports functionality

Vecka 3-4: Reporting & Insights - User activity tracking - Feature usage metrics - Tenant health scores - Audit log viewer UI - Scheduled reports (email delivery)

Fas 3 Features: ✅ Dashboard analytics (users, logins, API usage) ✅ Charts och visualizations ✅ Audit log viewer ✅ Report export (CSV, PDF) ✅ User activity tracking

Fas 4: Internationalization & Advanced Features (4-6 veckor)

Vecka 1-2: Internationalization - i18n framework setup (react-i18next eller vue-i18n) - Translations för 5 språk (SV, NO, DA, FI, EN) - Language switcher UI - Timezone handling - Localized date/time formats

Vecka 3-4: Advanced User Management - Teams/Groups functionality - Custom roles med granular permissions - Permission builder UI - Team assignment - User self-service portal (profile editing)

Vecka 5-6: Advanced Branding - Custom template creation - Template marketplace (internal) - Favicon upload - Dark mode support - Custom CSS injection (for advanced users)

Fas 4 Features: ✅ Multi-language support ✅ Teams functionality ✅ Custom roles och permissions ✅ Advanced branding options ✅ User self-service

Fas 5: Integrations & Enterprise Features (6-8 veckor)

Vecka 1-3: SSO Integration - SAML 2.0 implementation - OAuth 2.0 / OpenID Connect - Azure AD / Entra ID integration - JIT user provisioning - SSO configuration UI

Vecka 4-5: Webhooks - Webhook CRUD endpoints - Event subscription system - Webhook delivery service (queue-based) - Retry logic - Webhook logs och debugging UI

Vecka 6-8: API Ecosystem - API key management - Scoped permissions för API keys - OpenAPI (Swagger) documentation - API sandbox environment - Developer portal (basic)

Fas 5 Features: ✅ SSO (SAML, OAuth) ✅ Webhooks ✅ API keys med permissions ✅ API documentation ✅ Developer tools

Fas 6: Scale & Optimize (4-6 veckor)

Vecka 1-2: Performance Optimization - Caching layer (Redis) - Database query optimization - CDN setup för static assets - Code splitting och lazy loading - Performance monitoring setup

Vecka 3-4: Scalability - Horizontal scaling setup (load balancer) - Database read replicas - Asynchronous job processing (Sidekiq/Bull) - Auto-scaling configuration - Disaster recovery plan

Vecka 5-6: Enterprise Features - Custom domains per tenant - White-label login pages - Branded email templates - Advanced analytics (predictive metrics) - Multi-region support (if applicable)

Fas 6 Features: ✅ Performance optimizations ✅ Horizontal scaling ✅ Caching layers ✅ Custom domains ✅ White-label portal

Ongoing: Maintenance & Iteration

Continuous Activities: - Security updates och patches - Performance monitoring och optimization - User feedback incorporation - Bug fixes - Documentation updates - Compliance audits (GDPR, ISO 27001) - A/B testing new features - UX research och improvements

---

11. Prioriterad Feature-Lista för Utveckling

Must-Have (MVP - Fas 1)

Feature	Prioritet	Komplexitet	Värde
User CRUD	P0	Medium	Kritisk
3 Standard Roles	P0	Low	Kritisk
Role Assignment	P0	Medium	Kritisk
Branding Config (3 colors)	P0	Medium	Hög
Logo Upload	P0	Medium	Hög
8 Industry Templates	P0	Low	Hög
Live Preview (basic)	P0	High	Hög
Tenant Isolation	P0	High	Kritisk
API Authentication	P0	Medium	Kritisk
Basic Audit Logging	P0	Medium	Hög

Should-Have (Fas 2-3)

Feature	Prioritet	Komplexitet	Värde
2FA	P1	Medium	Kritisk
Bulk User Import	P1	Medium	Hög
User Notifications	P1	Low	Hög
Extended Colors (15)	P1	Low	Medium
Typography System	P1	Medium	Medium
Branding Versioning	P1	High	Hög
Analytics Dashboard	P1	High	Hög
Audit Log Viewer	P1	Medium	Hög
Rate Limiting	P1	Medium	Kritisk
Enhanced File Security	P1	Medium	Kritisk

Nice-to-Have (Fas 4-6)

Feature	Prioritet	Komplexitet	Värde
Multi-Language (i18n)	P2	High	Hög (för Norden)
Teams/Groups	P2	Medium	Medium
Custom Roles	P2	High	Hög
SSO Integration	P2	High	Hög (enterprise)
Webhooks	P2	Medium	Medium
API Keys	P2	Low	Medium
Custom Templates	P2	Medium	Low
Dark Mode	P2	Medium	Low
Custom CSS	P2	Low	Low

Custom Domains	P2	High	Medium (enterprise)

Future Consideration

Feature	Prioritet	Komplexitet	Värde
Mobile Apps (iOS/Android)	P3	Very High	Medium
GraphQL API	P3	High	Low
AI-Powered Features	P3	Very High	Medium
Template Marketplace	P3	High	Low
Advanced Analytics	P3	High	Medium
Multi-Region Deployment	P3	Very High	High (scale)

---

12. Teknisk Arkitektur Rekommendation

Tech Stack Förslag

Backend

```
Framework: Node.js + Express eller NestJS (TypeScript)
Alternativ: Python + FastAPI, Ruby on Rails, .NET Core

Motivering:
- NestJS: Enterprise-ready, TypeScript, god struktur, skalbar
- FastAPI: Modern, snabb, auto-generated API docs, typ-säkert
- Rails: Rapid development, conventions, mature ecosystem

Rekommendation: NestJS för bästa balans mellan produktivitet och
skalbarhet
```

Database

```
Primary: PostgreSQL 14+
Cache: Redis 6+
Search: Elasticsearch (om behövs för advanced search)

Motivering:
- PostgreSQL: Robust, JSONB support, Row-Level Security,
partitioning
- Redis: Snabb caching, session storage, rate limiting
```

Frontend

```
Framework: React + TypeScript eller Vue 3 + TypeScript
State Management: Redux Toolkit eller Zustand (React), Pinia (Vue)
```

```
UI Library: Material-UI (MUI), Ant Design, eller Chakra UI
Styling: Tailwind CSS + CSS-in-JS för dynamic theming

Rekommendation: React + TypeScript + MUI + Tailwind
- React: Största ecosystem, bästa tooling
- TypeScript: Type safety, bättre developer experience
- MUI: Professional look, accessibility, theming support
- Tailwind: Utility-first, snabb utveckling, easy customization
```

File Storage

```
Cloud: AWS S3, Google Cloud Storage, eller Azure Blob Storage
CDN: CloudFront, Cloudflare

Motivering:
- Skalbart, durability (99.999999999%)
- Billigt för storage
- CDN för global distribution och caching
```

Authentication

```
JWT: jsonwebtoken (Node.js), PyJWT (Python)
2FA: speakeasy (TOTP), Twilio (SMS)
SSO: passport-saml, node-saml

Rekommendation: JWT för tokens, speakeasy för 2FA, passport-saml för
SSO
```

Job Queue

```
Node.js: Bull (Redis-based), BullMQ
Python: Celery (Redis/RabbitMQ backend)
Ruby: Sidekiq

Rekommendation: Bull eller BullMQ för Node.js projects
```

Testing

```
Unit Tests: Jest (Node.js), pytest (Python)
E2E Tests: Playwright, Cypress
API Tests: Supertest, Postman/Newman
Load Tests: k6, Artillery

Rekommendation: Jest + Playwright för comprehensive testing
```

Monitoring & Logging

```
APM: Datadog, New Relic (paid), eller Elastic APM (open-source)
Logging: Winston (Node.js) + ELK stack
Error Tracking: Sentry
Uptime Monitoring: UptimeRobot, Pingdom
```

```
Rekommendation: Sentry för errors + ELK for logs + Datadog för APM
```

Infrastructure

```
Hosting: AWS, Google Cloud, Azure, eller DigitalOcean
Container: Docker
Orchestration: Kubernetes (för stora installationer), Docker Compose
(för mindre)
CI/CD: GitHub Actions, GitLab CI, CircleCI

Rekommendation: AWS med Docker + Kubernetes för skalbarhet
```

Folder Structure (NestJS exempel)

```
unicorn-backend/
├── src/
│   ├── common/                 # Shared utilities
│   │   ├── decorators/
│   │   ├── filters/
│   │   ├── guards/
│   │   ├── interceptors/
│   │   ├── middleware/
│   │   └── pipes/
│   ├── config/                 # Configuration
│   │   ├── database.config.ts
│   │   ├── jwt.config.ts
│   │   └── app.config.ts
│   ├── modules/
│   │   ├── auth/               # Authentication & Authorization
│   │   │   ├── auth.controller.ts
│   │   │   ├── auth.service.ts
│   │   │   ├── auth.module.ts
│   │   │   ├── strategies/     # JWT, SAML strategies
│   │   │   └── dto/
│   │   ├── tenants/            # Tenant management
│   │   │   ├── tenants.controller.ts
│   │   │   ├── tenants.service.ts
│   │   │   ├── tenants.module.ts
│   │   │   ├── entities/tenant.entity.ts
│   │   │   └── dto/
│   │   ├── users/              # User management
│   │   │   ├── users.controller.ts
│   │   │   ├── users.service.ts
│   │   │   ├── users.module.ts
│   │   │   ├── entities/user.entity.ts
│   │   │   └── dto/
│   │   ├── roles/              # Role & Permission management
```

```
│   │   ├── teams/              # Team management
│   │   ├── branding/           # Branding configuration
│   │   │   ├── branding.controller.ts
│   │   │   ├── branding.service.ts
│   │   │   ├── branding.module.ts
│   │   │   ├── entities/
│   │   │   │   ├── branding-config.entity.ts
│   │   │   │   └── branding-template.entity.ts
│   │   │   └── dto/
│   │   ├── files/              # File upload & management
│   │   ├── analytics/          # Analytics & metrics
│   │   ├── audit-logs/         # Audit logging
│   │   ├── webhooks/           # Webhook management
│   │   └── notifications/      # Email, SMS notifications
│   ├── database/
│   │   ├── migrations/         # Database migrations
│   │   └── seeds/              # Seed data (templates, roles)
│   ├── jobs/                   # Background jobs
│   │   ├── email.processor.ts
│   │   ├── analytics.processor.ts
│   │   └── webhook.processor.ts
│   └── main.ts
├── test/                       # E2E tests
├── Dockerfile
├── docker-compose.yml
├── package.json
└── tsconfig.json

unicorn-frontend/
├── public/
│   ├── locales/                # i18n translations
│   │   ├── sv/
│   │   ├── en/
│   │   ├── no/
│   │   └── da/
│   └── index.html
├── src/
│   ├── api/                    # API client
│   │   ├── client.ts
│   │   ├── endpoints/
│   │   │   ├── auth.ts
│   │   │   ├── users.ts
│   │   │   ├── branding.ts
│   │   │   └── ...
│   ├── components/             # Reusable components
│   │   ├── common/             # Buttons, Inputs, etc.
│   │   ├── layout/             # Header, Sidebar, Footer
│   │   └── features/           # Feature-specific components
```

```
│   ├── pages/                  # Page components
│   │   ├── Dashboard/
│   │   ├── Users/
│   │   │   ├── UserList.tsx
│   │   │   ├── UserForm.tsx
│   │   │   └── BulkImport.tsx
│   │   ├── Branding/
│   │   │   ├── BrandingEditor.tsx
│   │   │   ├── TemplateSelector.tsx
│   │   │   └── LivePreview.tsx
│   │   ├── Analytics/
│   │   └── Settings/
│   ├── hooks/                  # Custom React hooks
│   │   ├── useAuth.ts
│   │   ├── useTenant.ts
│   │   └── useBranding.ts
│   ├── store/                  # State management (Redux/Zustand)
│   │   ├── slices/
│   │   │   ├── auth.slice.ts
│   │   │   ├── tenant.slice.ts
│   │   │   └── branding.slice.ts
│   │   └── store.ts
│   ├── theme/                  # Theming system
│   │   ├── ThemeProvider.tsx
│   │   ├── createDynamicTheme.ts
│   │   └── defaultTheme.ts
│   ├── utils/                  # Utility functions
│   │   ├── validation.ts
│   │   ├── formatting.ts
│   │   └── permissions.ts
│   ├── types/                  # TypeScript types
│   │   ├── api.types.ts
│   │   ├── user.types.ts
│   │   └── branding.types.ts
│   ├── i18n/                   # i18n configuration
│   │   └── i18n.ts
│   ├── App.tsx
│   └── main.tsx
├── Dockerfile
├── package.json
├── tsconfig.json
└── vite.config.ts              # or webpack.config.js
```

---

13. Sammanfattning & Nästa Steg

Översikt

System Dashboard-specifikationen för Unicorn är **välgenomtänkt och solid som MVP**, men kräver förbättringar inom säkerhet, skalbarhet, och användarupplevelse för att bli enterprise-ready.

Styrkor

✅ Tydlig multi-tenant arkitektur ✅ Omfattande white-labeling funktionalitet ✅ Genomtänkt rollbaserad åtkomstkontroll ✅ Innovativt industrimall-koncept ✅ Live preview-funktionalitet

Kritiska Förbättringsområden

🔴 **Säkerhet:** Audit logging, data isolation, 2FA, compliance (GDPR) 🔴 **Backup:** Branding versioning, rollback-mekanismer 🔴 **Internationalisering:** Multi-språk stöd för Norden (kritiskt!) 🔴 **Användarhantering:** Bulk operations, notifikationer, self-service

Rekommenderad Approach

Fas 1 (MVP): Implementera grundläggande funktionalitet enligt original spec + kritiska säkerhetsförbättringar (audit logs, data isolation, 2FA).

Fas 2-3: Lägg till enhanced UX (bulk import, notifications), analytics, och branding extensions.

Fas 4-6: Internationalisering, SSO, webhooks, och enterprise features.

ROI-Fokus

Snabbast värde: 1. ✅ MVP features → Möjliggör white-labeling omedelbart 2. 🔒 Kritisk säkerhet → Förhindrar framtida problem 3. 🌍 Internationalisering → Öppnar hela Norden-marknaden 4. 📊 Analytics → Data-driven beslut och product-market fit

Långsiktig investering: 5. 🔗 Integrationer (SSO, webhooks) → Enterprise customers 6. 📈 Skalbarhet → Hantera tillväxt 7. 🤖 AI-features → Differentiation

Success Metrics

Technical: - Uptime: > 99.9% - API response time: < 200ms (p95) - Page load time: < 2s

Business: - Tenant onboarding time: < 10 minutes - Time to first branding customization: < 5 minutes - User creation time: < 2 minutes (single), < 10 minutes (bulk 50 users) - Support tickets

related to System Dashboard: < 5% av total

User Satisfaction: - NPS score: > 50 - Feature adoption: > 80% av tenants använder branding inom första veckan - Churn rate: < 5% annually

Nästa Steg

1. **Validera:** Review detta dokument med stakeholders och tech team
2. **Prioritera:** Finalize feature prioritization baserat på business goals
3. **Planera:** Detaljerad sprint planning för Fas 1 (MVP)
4. **Prototypa:** Skapa high-fidelity mockups för key screens (använd bifogad HTML mockup som utgångspunkt)
5. **Bygga:** Kickoff development med fokus på security-first approach
6. **Testa:** Continuous testing och user feedback
7. **Lansera:** Beta launch med utvalda tenants, sedan gradually roll out
8. **Iterera:** Kontinuerlig förbättring baserat på metrics och feedback

---

Bilaga A: Nordiska Marknaden Considerations

Språk & Lokalisering

Svenska (primär) - Formellt “ni” vs informellt “du” (välj en ton konsekvent) - Svensk terminologi för tech terms (användarroller, behörigheter, inställningar) - Svenska datumformat (YYYY-MM-DD är standard i Sverige)

Norska - Bokmål (primär) + Nynorsk (optional) - Liknande Svenska men vissa ord skiljer sig (brukere vs användare)

Danska - Liknande Svenska/Norska men egen identitet - Viktigt att inte “automatöversätta” från Svenska

Finska - Helt annat språk (Finno-Ugric, inte Indo-European) - Kräver professionell översättning - Långa sammansatta ord kan påverka UI design

Affärskultur

Nordisk enkelhet - Preferens för minimalistisk design - Mindre är mer - undvik “bloat” - Fokus på funktionalitet över form

Transparens & Trust - Tydliga priser (inga dolda kostnader) - GDPR-compliance är förväntat, inte optional - Open communication om system status

Jämlikhet - Flat organizational structures är common - Role-based access bör vara flexibel (inte rigid hierarchies) - Team-centric features värderas högt

Juridiska Krav

GDPR (EU-förordning) - Obligatorisk för alla Nordiska länder - Straffavgifter upp till 4% av global omsättning - User consent, right to access, right to deletion

Data Residency - Vissa kunder kräver data inom EU/Nordisk region - AWS EU (Stockholm, Frankfurt), Google Cloud EU, Azure EU

E-invoicing Standards - Peppol BIS Billing 3.0 (common i Norden) - EHF (Norge), Svefaktura (Sverige) - Relevant om Unicorn hanterar fakturering

Betalning & Valuta

Valutor - Sverige: SEK (kr) - Norge: NOK (kr) - Danmark: DKK (kr) - Finland: EUR (€)

Betalningsmetoder - Swish (Sverige) - mobil betalning, mycket populär - Vipps (Norge) - motsvarighet till Swish - MobilePay (Danmark) - ditto - Banköverföring är vanligt för B2B - Kreditkort (Visa, Mastercard) - Autogiro/AvtaleGiro för prenumerationer

Konkurrensanalys (Exempel)

Internationella aktörer i Norden: - Salesforce (CRM + Field Service) - ServiceTitan (US-baserad Field Service) - Jobber (kanadensisk, expanderar till EU)

Nordiska/Lokala aktörer: - Planday (Danmark, workforce management) - Quinyx (Sverige, workforce management) - TimeZynk (Sverige, field service) - Moment (Norge/Sverige, booking & scheduling)

Unicorns differentiation: - 🎯 Fokus på SMB (inte enterprise) - 🎨 White-labeling som core feature (många konkurrenter saknar detta) - 🌍 Nordisk-först approach (språk, kultur, payment methods) - 💰 Transparent pricing för SMB budgets

---

Bilaga B: Ordlista (Svenska Tech Terms)

English	Svenska	Notes
User	Användare	Standard term
Role	Roll	Användarroll
Permission	Behörighet / Tillstånd	Behörighet är vanligare
Owner	Ägare	Företagsägare
Admin	Administratör / Admin	Admin är OK informellt
Branding	Varumärkesanpassning	Eller bara “Branding” (accepterat)
Template	Mall	Standard term
Dashboard	Instrumentpanel / Dashboard	Dashboard är vanligare inom tech
Settings	Inställningar	Standard
Audit Log	Granskningslogg / Händelselogg	Granskningslogg för compliance
Tenant	Kund / Hyresgäst	“Kund” i multi-tenant SaaS context
White-labeling	White-labeling	Ingen bra svensk översättning, behåll engelska
Webhook	Webhook	Behåll engelska
API	API	Behåll engelska
Two-Factor Authentication	Tvåfaktorsautentisering / 2FA	2FA är OK
Single Sign-On	Enkel inloggning / SSO	SSO är OK

Dokument skapat: 2025-12-26
Version: 1.0
Författare: DeepAgent AI
För: Unicorn System Dashboard Project